

ScopeFirm: Independent Due-Diligence Audit

Product: <https://scopefirm.vercel.app> · Repo: [kaust1495/scopefirm](https://github.com/kaust1495/scopefirm) (audited at `aa960e5` ; fixes pushed as branch `claude/happy-mayer-j6u1e2`) · Date of all checks: 28 Sep 2026 · Evidence labels: **CONFIRMED** observed · **INFERRED** reasoned from evidence · **HYPOTHESIS** needs testing

Inputs left blank in the brief (goal, budget, market): I assumed India-first solo freelance web builders (the product prices in ₹ and shows IST), evenings-only time and ₹0 marketing. Where the goal changes the answer, both answers are given.

Executive verdict. As a business, the current ScopeFirm is weak. Its core loop (write a fixed-price scope, share a link, the client accepts, a dated record is kept) is already free in tools your buyer already has. Zoho Invoice is free for Indian businesses and lets clients accept quotes in a portal [1][2]. Refrens lets clients accept quotations online [4]. Indy's free plan includes proposals and e-signed contracts [6]. A newer group of scope-creep tools goes past ScopeFirm and targets the same buyer. ScopeGuard (freelance web designers, free plan) [9], ScopeDue (\$29/mo, priced change approvals with payment proof) [8] and ScopeCtrl (Gmail extension that detects scope creep and generates change orders, free or \$9/mo) [10] all exist. The product also had a showstopper: on the code that was live, **every "Create quote" landed on a 404 page**. I confirmed this on a local production build of the deployed commit; that the live site behaves the same is inferred, not tested. It is now fixed and pushed, along with 8 security and UX fixes. If your goal is a **portfolio piece**, it is now a good one: small, careful and security-aware. For **side income**, don't build further until you have pre-sold a narrower wedge. The only angle I could not find already shipped is *India-specific*: a change approval that collects a UPI advance before extra work starts, shared over WhatsApp. That is a hypothesis with no willingness-to-pay evidence behind it, and Refrens or Zoho could copy it quickly. For a **full startup**: no.

1. What the product does today (observed)

Step	Observed behaviour	Label
Quote builder /	Form: client, project, client's ask, deliverables, exclusions, fixed ₹ price, revision rounds. No account. Live page matches the repo source [L1].	CONFIRMED live + code
Create quote	At <code>aa960e5</code> : the server action redirects to a route handler (<code>/quotes/[id]/access?key=...</code>). The client router renders 404 , and the cookie is only set if the user reloads. The freelancer is never shown the editor link again.	CONFIRMED local prod build of the same commit · INFERRED live (same code; I stopped live testing, see §8)
Private tracker /quotes/[id]	Edits create revision N+1; the activity timeline is shown in IST; delete requires typing a confirmation phrase. Access is a 30-day HttpOnly cookie scoped to the quote path.	CONFIRMED local test
Client view /q/[id]	Anyone with the link can accept the current revision or request changes. No identity check (the page says so). Showed the internal status "DRAFT" to the client.	CONFIRMED local test
Missing	No account or dashboard listing your quotes, no email/WhatsApp notifications, no payment, no PDF, no terms page.	CONFIRMED code

2. Is the problem real and painful?

CONFIRMED Scope creep is a widely reported pain. Squarespace's 2026 survey of 1,034 web designers ranks it the #2 challenge (37%), behind finding clients (47%) [11]. Squarespace sells to this audience, so treat that as a directional signal, not market sizing. Reddit threads show individual losses, e.g. "Lost \$2300 to scope creep on one project" [12]. These are **complaints, not payments**. Ignore the "57% of freelancers lose \$1K+/month" figure: it comes from an idea-list site with no method shown [13].

INFERRED The pain is sharpest for fixed-price web freelancers after kickoff, when "one small change" arrives over chat. ScopeFirm today acts *before* kickoff (the initial quote). That is the lower-pain moment, and it is where free tools are strongest.

3. Competitors (verified 28 Sep 2026 on vendor pages unless marked)

Ring	Product	What it does (vs ScopeFirm)	Verified price	Threat
a	ScopeGuard [9]	Same buyer (freelance web designers/devs): tracks agreed pages, revisions, client requests, hours; says when extra work should be charged	Free plan for 2 active projects; paid tiers exist (€15 figure unverified ; page blocked to my tools)	High
a	ScopeDue [8]	Priced change-approval links, payment ledger, handoff lock, "Proof Packs", e-sign	\$29/mo, 30-day trial	High (US-oriented)
a	ScopeCtrl [10]	Scope-creep detection in Gmail (extension) and Slack; change-order generation; proposals	Free (3 projects, 15 AI analyses/mo); Plus \$1/mo launch, \$9/mo regular	High
a	Salag [14]	Approve-by-link, timestamped approvals and change requests, payment matching; built for Filipino freelancers (a local-market play like yours)	Free: 3 clients, 5 agreements/mo	Low in India; proof the local-wedge idea is being tried
a	ScopePilot	Cited by the other audit at \$14.99/mo	Unverified : domain did not resolve on 28 Sep 2026	Unknown
b	Zoho Invoice [1][2]	Quotes, client-portal acceptance, quote → invoice, UPI/card payments, WhatsApp sending	₹0 for Indian businesses (limit 500 invoices/yr)	Very high
b	Refrens [3][4][5]	Indian quotation/invoice tool; client accepts quotation online; eSign; payments	15 documents free; premium price not published	Very high
b	Indy [6]	Proposals + e-signed contracts + invoices	Free: 3 proposals, 3 contracts/mo; Pro \$12.50/mo (billed 2-yearly)	Medium
b	Bonsai [7][15]	Proposals with one-click client e-approval, deposit capture, contracts	\$9–\$59/user/mo by tier and billing; proposals from Essentials; no free plan	Medium (price-sensitive India)
b	PandaDoc [16]	eSign	Free: 5 docs/mo; Starter \$19/user/mo annual (third-party summary, dated Mar 2026)	Low
b	RunoSO [17]	Indian freelancer OS: clients, projects, GST invoices. No scope/approval feature seen	Free; Solo ₹169; Pro ₹399	Low now; sets the Indian price anchor
b	Notion "Scope Creep Detector" template [18]	AI checks requests against your agreement, drafts boundary messages	Price not verified	Medium
c	WhatsApp / email / Google Doc	"Please confirm by replying OK." Free, where the client already is.	₹0	Highest : the default you must beat

4. Is the current product differentiated?

No. CONFIRMED A shareable quote the client can accept is free in Zoho Invoice and Refrens, both Indian and both with UPI. Scope-change tracking for web freelancers is shipped by ScopeGuard (free tier). Priced change approval is shipped by

ScopeDue. What ScopeFirm has left is small: no signup for the freelancer, revision-exact acceptance, and a clean UI. None of those is a reason to pay.

5. Willingness to pay: the money moment

INFERRED The money moment is not "send a quote". It is: **the client asks for extra work → the freelancer sends a priced change → the client approves and pays an advance → work starts**. That turns avoided losses into cash.

Evidence strength: **weak**. **CONFIRMED** People pay for all-in-one suites (Bonsai, HoneyBook), but vendor user counts are not paying-customer counts. I found **no public paying-customer evidence** for any scope-only tool (ScopeDue, ScopeGuard, ScopeCtrl). ScopeCtrl's \$1 launch price suggests it is still searching for demand **INFERRED**. Nothing yet shows that Indian freelancers pay for this.

6. Pricing hypotheses (all **HYPOTHESIS**, untested)

Option	Anchor	Note
Free: 2 active projects, unlimited quotes	ScopeGuard free (2 projects), Zoho ₹0	Required to compete at all
Solo ₹199–₹299/mo or ₹1,999/yr	RunoSO ₹169/₹399 [17]; ScopeCtrl \$9 [10]	The other audit's ₹799–999 is 2–5× the Indian anchors. Test it, but expect resistance.
Per-use: ₹49 per approved change order with payment collected	Payment gateway fees (not verified here)	Ties price to the money moment; zero cost when idle

7. UX audit

Action	Item	Status
Fix	404 after "Create quote"	Fixed
Fix	Editor link never shown, so access is lost after 30 days or on another device	Fixed: masked link with Show/Copy and a "save now" prompt
Fix	Client saw the internal "DRAFT" label	Fixed: "Awaiting your review"
Fix	No confirmation after delete	Fixed
Add	A list of "my quotes" (today each quote is a separate secret link)	Open: needs login (magic link) · 1–2 days
Add	Share on WhatsApp button with pre-filled text; notify the freelancer on accept	Open · 0.5 day / 1 day
Add	Define "revision round"; structured deliverables (pages, forms, CMS yes/no); timeline	Open · 1–2 days
Remove / simplify	Hero copy and three "pill" anchors repeat the form; put a sample client view at the top instead	Open · 0.5 day

8. Security and architecture assessment

Method: live checks were passive (headers via securityheaders.com, route probe, page fetch). One attempt to create a live test record failed with an error in my browser tool. Under your stop rule I then ended all live testing. XSS, tampering and access tests ran on a local production build of the same commit. **Test records:** none confirmed on live. Because that one attempt errored, check for and delete any row with `project = 'AUDIT-TEST-2026-09-28'` (client starts `AUDIT-TEST`). All other test data lived in the local, git-ignored `scopefirm.db` and never touched Turso.

#	Finding	Grade	Sev.	Evidence	Fix / effort
---	---------	-------	------	----------	--------------

1	Create flow shows 404; cookie never set	Confirmed (functional)	High	Playwright screenshot on local prod build; <code>actions/index.ts</code> redirect to route handler	Set cookie in the action and redirect to the page. Fixed
2	Attacker-chosen text shown on the real domain via <code>?error=</code> (e.g. "Pay deposit to UPI evil@upi")	Confirmed vulnerability (content spoofing; React escaped it, so not XSS)	Medium	<code>curl</code> showed the text inside <code>role="alert"</code> on <code>/</code> and <code>/q/[id]</code>	Allow-listed error codes. Fixed
3	No rate limit on anonymous creation or client responses (database-filling, cost abuse)	Likely risk (not load-tested per rules)	Medium	Code	DB-backed limits: 20/h/IP, 20/h/quote. Fixed (basic; a Vercel WAF rule is stronger)
4	Client identity not verified; "approval" is weak proof	Likely risk (by design, disclosed)	Medium	UI text, code	Typed name required and recorded (done). Client email OTP: 1–2 days
5	Quote update and history insert not atomic (lost history on failure)	Best-practice gap	Low	<code>store.ts</code>	Single transaction with <code>changes()=1</code> guard. Fixed
6	Route's <code>Referrer-Policy: no-referrer</code> overridden by the global header on the key-bearing URL	Confirmed (config)	Low	<code>curl -i</code> showed <code>strict-origin-when-cross-origin</code>	Path-level header entry. Fixed , verified
7	Editor key copied into every history snapshot	Best-practice gap	Low	<code>JSON.stringify(q)</code>	Stripped for new rows. Fixed . Old rows: <code>UPDATE history SET snapshot=json_remove(snapshot, '\$.edit_key')</code>
8	Non-constant-time key comparison	Best-practice gap	Low	Code	<code>timingSafeEqual</code> . Fixed
9	Secret key in a URL (browser history, request logs)	Likely risk	Low	Design	Mitigated (exchanged for a cookie, no-referrer). Real fix is accounts · 1–2 days

10	CSP allows 'unsafe-inline' scripts	Best-practice gap	Low	securityheaders.com grade A, capped by this warning [L2]	Nonce CSP via Next proxy · 0.5–1 day. Not done
11	Stored XSS in 5 fields + change note	Tested-negative	—	Payload "><script>" rendered as text; no dialogs	—
12	Hidden-field tampering (revision, kind)	Tested-negative	—	Rejected with stale/invalid errors	—
13	Tracker without cookie / wrong key (IDOR)	Tested-negative	—	404 both. IDs are randomBytes(12) (96-bit random, no timestamp), read from code rather than inferred from format	—
14	CSRF on server actions	Cannot verify beyond framework	Low	Next compares Origin to Host; requests with no Origin are allowed with a warning [19]	—
15	Secrets in client bundles	Tested-negative (local build); live bundle contents not scanned	—	No NEXT_PUBLIC vars; no TURSO/libsql strings	—
16	Dependencies	Tested-negative	—	npm audit --omit=dev:0 vulnerabilities	Enable Dependabot · 10 min
17	Headers: HSTS preload, CSP, XFO DENY, nosniff, Permissions-Policy	Confirmed present (live)	—	[L2]	—
18	Turso backups, access control, tamper evidence	Cannot verify without internal access	?	—	Check Turso point-in-time recovery; hash-chain history rows · 1 day
19	No Terms page; no data export	Best-practice gap	Low	A privacy page exists (/privacy)	0.5 day

Architecture. Next.js 16 server actions, libSQL/Turso, no accounts, capability URLs. This is appropriate for a prototype. Regression suite: 26 end-to-end checks all pass after the fixes, and lint and build are clean. **Deployment:** the fixes are on the branch only. Production changes when the branch is merged to `main`. New tables are created automatically on first request.

9. Channel fit

Channel	Reaches this buyer at the moment of need?	Verdict
Mobile-first web app + WhatsApp share link	Yes. INFERRED Indian client requests mostly arrive on WhatsApp (not verified with data). The freelancer creates the change on a phone and sends the link in the same thread.	Build this
Gmail / browser extension	Partly: fits email-heavy, overseas-client freelancers. ScopeCtrl already ships this [10].	Reject as the wedge
WhatsApp Business API bot	Yes, but per-conversation cost and Meta approval overhead	Later, if at all
WordPress plugin	No: the plugin lives on the client's site, and the change request happens elsewhere	Reject
Shopify / Apify / public API	No: wrong buyer and no scraping job	Reject
Marketplaces (Upwork/Fiverr)	No: those platforms already run milestones and escrow, and don't allow off-platform tools in the flow	Reject (INFERRED)

10. Positioning and biggest risk

HYPOTHESIS "Paid before you build it: send a change, get UPI advance, then start." For India-based freelance web builders who work with clients over WhatsApp. **Biggest risk:** Refrens or Zoho Invoice adds "change order" to quotes. Both already have quotes, client acceptance and UPI collection [1][4][5], so it is a small feature for them and would take weeks. Second risk: the do-nothing default. Many freelancers won't send a formal change to a client they want to keep.

11. Roadmap (ranked)

#	Item	Impact	Effort	Risk	Revenue link
1	Change request on an accepted quote (child record, price, days added)	High	2 days	Low	Direct
2	UPI advance on approval (payment link; mark paid via webhook)	High	2–3 days	Medium (payments, KYC)	Direct
3	WhatsApp share + freelancer notification	High	1 day	Low	Indirect
4	Magic-link login + quote list	Medium	1–2 days	Low	Needed to charge
5	Client email/phone OTP on accept; PDF record	Medium	2 days	Low	Trust
6	AI "is this in scope?" helper	Low (already commoditised)	2 days	Medium	Weak

12. Prioritized fix list

1. **Merge the branch to production** (fixes 1–8 above) · 15 min. Then run the history SQL cleanup (§8 #7) · 5 min.
2. Delete any live AUDIT-TEST-2026-09-28 row · 5 min.
3. Nonce-based CSP · 0.5–1 day.
4. Terms page; data export · 0.5 day.
5. Vercel WAF rate-limit rule on POST / and /q/* · 1 hour.
6. Dependabot + secret scanning on the repo · 10 min.
7. Hash-chained history (each row stores the hash of the previous one) · 1 day.

13. 30/60/90 days (validation first)

Window	Do	Go / no-go
Days 1–30	Interview 15 Indian freelance web builders. Ask each to <i>show</i> the last out-of-scope request (the WhatsApp thread), what they did, and what it cost them. Offer a concierge pilot: you send their next change order by hand using ScopeFirm plus a UPI link. Pre-sell ₹1,999/yr (refundable).	Go if ≥8/15 show a recent unpaid extra ≥₹5,000 AND ≥3 pre-pay. Kill if <3 pre-pay, or if people who pay say Zoho or Refrens would do.
Days 31–60	Build roadmap items 1–4 for the pilots only. Measure change orders sent, approved and paid.	Go if ≥40% of change orders sent are approved and paid through the link, and pilots use it without prompting. Kill if clients refuse to pay through links (freelancers revert to WhatsApp "OK").
Days 61–90	Open a public free tier; post in Indian freelancer communities; convert pilots to paid.	Go if ≥10 paying and ≥₹5,000 MRR equivalent. Otherwise keep it as a portfolio piece.

14. What I would build

Product	ScopeFirm Change: after a quote is accepted, turn any extra request into a priced change the client approves and pays an advance on, from one WhatsApp link.
Ideal customer	India-based solo freelance web builders, fixed-price projects of ₹15k–₹2L, clients on WhatsApp
Core paid feature	Approval that includes UPI advance collection, with a dated, revision-exact record
Pricing hypothesis	Free: 2 projects. ₹199/mo or ₹1,999/yr, or ₹49 per paid change (test both)
Distribution	Direct outreach in Indian freelancer communities; every client link carries a "Made with ScopeFirm" footer
Minimum launchable version	Today's app + change request + payment link + WhatsApp share + magic-link login

Self-check: attempts to disprove the top findings

- **404 on create:** reproduced 3 times with Playwright on `next start` of commit `aa960e5`. Direct curl of the route handler works (307 + cookie), which isolates the bug to the action → route-handler redirect. *Not reproduced on live* (testing stopped). The live headers match the repo config exactly, so it is the same code: INFERRED.
- **Content spoofing:** first seen in page HTML; my first "after fix" test flagged a false positive (the text sat only inside Next's router-state JSON, which is inert). Re-checked on visible text: fixed.
- **"Core feature is free elsewhere":** Zoho Invoice's quote acceptance requires the client-portal setup [2], which adds client friction. That is a weakness in Zoho, but Refrens also advertises online acceptance [4]. The finding holds.
- **Recommended wedge already shipped?** ScopeDue has priced approval with payment tracking (USD, Stripe-style) [8]. Salag does payment matching for the Philippines [14]. I found no India/UPI/WhatsApp-native change-approval tool, but my search was limited. Treat the gap as **HYPOTHESIS**.

Corrections / uncertainties (including where the other audit you shared is wrong)

- It says there is "no visible privacy policy": wrong. `/privacy` is linked in the footer. No Terms page: correct.
- It lists security headers and ID predictability as "cannot verify": both are now verified. Headers are grade A; IDs are 96-bit random.
- It could not test the create flow, so it missed the P0: creating a quote showed a 404.
- Its moat recommendation (Gmail capture and AI scope detection) is already shipped by ScopeCtrl, free or \$9/mo [10]. Dropped.
- Its ScopePilot \$14.99 price: the domain did not resolve on 28 Sep 2026. ScopeGuard €15: not verified (page blocked to my tools); its free plan was confirmed. Notion template \$7.99: not verified.
- Its ₹799–999 Solo price is untested and high against Indian anchors (RunoSO ₹169/₹399, Zoho ₹0).

- Bonsai: my extraction tool mislabelled monthly and annual prices. I report the range \$9–\$59/user/mo. Third-party sites disagree (\$15–\$59) [15].
- Upwork/Fiverr escrow claim: no primary source fetched (tool error). Unverified.
- Your brief left the product URL, goal, budget and market blank. You confirmed the URL mid-run; the others are assumptions.

Sources

1. Zoho Invoice India pricing: <https://www.zoho.com/in/invoice/pricing> (checked 28 Sep 2026)
2. Zoho Invoice help, accepting quotes through Customer Portal: <https://cdn.zoho.com/invoice/help/estimate/estimate-accept.html>
3. Refrens pricing: <https://www.refrens.com/pricing>
4. Refrens quotation maker ("client can review and accept it online"): <https://www.refrens.com/en/free-online-quotation-generator>
5. Refrens what's new (eSign): <https://www.refrens.com/grow/whats-new-in-refrens/>
6. Indy pricing: <https://weareindy.com/pricing>
7. Bonsai proposals (client e-approval, deposit capture): <https://www.hellobonsai.com/proposals> · pricing <https://www.hellobonsai.com/pricing>
8. ScopeDue: <https://scopedue.com/>
9. ScopeGuard: <https://scopeguard.io/>
10. ScopeCtrl: <https://www.scopectrl.com/>
11. Squarespace Circle, State of the Web Design Industry 2026: <https://pros.squarespace.com/web-design-industry-report>
12. Reddit r/freelance, "Lost \$2300 to scope creep": <https://www.reddit.com/r/freelance/comments/1ozc3zq/>
13. MicroGaps (idea-list site; unreliable stat): <https://www.microgaps.com/gaps/scope-creep-change-order-freelancers>
14. Salag: <https://salag.app/>
15. Taskip Bonsai pricing summary (third party): <https://taskip.net/bonsai-pricing>
16. PandaDoc pricing: <https://www.pandadoc.com/pricing/> ; plan details via <https://eversign.com/blog/pandadoc-pricing-guide> (third party)
17. RunoSO: <https://www.runoso.in/>
18. Notion template: <https://www.notion.com/templates/scope-creep-detector-for-freelancers>
19. Next.js serverActions config (CSRF origin check): <https://nextjs.org/docs/app/api-reference/config/next-config-js/serverActions>
20. [L1] Live page: <https://scopefirm.vercel.app/> · [L2] Header scan: <https://securityheaders.com/?q=https%3A%2F%2Fscopefirm.vercel.app%2F> (28 Sep 2026 14:25 UTC)
21. Fix commit: github.com/kaust1495/scopefirm, branch `claude/happy-mayer-j6u1e2`